Admin Panel and RBAC: Implementation Status

As of 28 Oct 2026. Branch: feature/admin-panel (local work, not yet committed).

Graph RAG backend (branch feature/graph-rag)

DONE

- Sources: pdf, csv, json rows, markdown and text. Parsed, chunked and sent to Gemini chunk by chunk with no database transaction held.
- Validation gate before anything reaches the graph: schema, both entities present in the chunk text, no self-loops, confidence threshold, and a verbatim supporting quote.
- Graph in Postgres tables with company_id on every row, composite foreign keys so rows cannot reference another company, and an evidence table linking every fact to its source chunk.
- Update and delete: new content goes in before old content goes out, then unsupported relations and entities are pruned. Same file is a no-op, a failed update keeps the old graph.
- Retrieval: question words matched to entities, breadth-first expansion over relations in both directions with node and edge caps, ranked by distance, source support and confidence. Falls back to keyword plus vector search over chunk embeddings (pgvector).
- Answers: the model sees only the retrieved context. Every citation must point to a real passage and its quoted text must appear in it, otherwise the answer is a refusal. Nothing retrieved means no model call.
- Errors: failed chunks are skipped and reported (partial), model outages give 502, timeouts 504, bad output is retried once. User messages stay generic.
- Audit rows for ingest, update, delete and query, with the effective company. Per-company rate cap on writes and queries.

VERIFIED

- 89 backend tests pass on sqlite with a scripted fake model, and the same suite passes on a scratch Postgres 17 database with pgvector. That run found one real bug (wrong-size embeddings crashing the insert), now fixed and tested.
- Not verified: the real Gemini calls. There is no GEMINI_API_KEY in this environment, so the Gemini client (structured output, model ids, embeddings) has never run against the live API.

KNOWN LIMITS

- No check that a claim follows from its quote, only that the quote is real.
- No OCR, no alias merging between entity names, ingest is synchronous with size caps, per-process rate counter, tables created at startup instead of migrations.
- The vector similarity floor (0.6) is a starting value to tune with real embeddings.

Admin panel (branch feature/admin-panel)

DONE

BACKEND (FASTAPI, BACKEND/)

- Login with email and password, bcrypt hashes, JWT access tokens (60 minutes).
- Roles sysAdmin, admin and user with a fixed permission map. Every admin route checks its permission on the server.
- Company isolation: one helper scopes every query to the user’s company. Another company’s records return 404.
- Admin APIs: companies (sysAdmin), users (admin for own company, sysAdmin for all), audit log.
- Rules: a company keeps at least one active admin, no self role or status change, only a sysAdmin creates a sysAdmin, no new users in an inactive company.
- Audit log: written in the same transaction as each change, append-only. Includes failed logins.
- Signup: creates a new company and its first admin.

CONFIDENTIAL

- Password reset: forgot-password and reset-password. Single-use token, 15 minutes, same reply for unknown emails. Reset tokens cannot be used as login tokens.
- First sysAdmin created at startup from SYSADMIN_EMAIL and SYSADMIN_PASSWORD when no users exist.

ADMIN UI (REACT, ADMIN-UI/)

- Sign in, create company, forgot password and set new password screens.
- Role-aware navigation: Users, Companies (sysAdmin only), Audit log. Users with the user role see a no-access message.
- Users page: add, change role, deactivate and restore. Controls that are not allowed for a row are hidden.
- Companies page: add, deactivate and restore.
- Audit log page with an action filter.

DOCUMENTS (DOCS/)

- Approved plan, API endpoint list for testers with 31 test cases, and this status note.

VERIFIED

- 17 automated backend tests pass: 401 and 403 checks, cross-company access, sysAdmin access, audit rows, admin rules, signup, single-use password reset.
- Live test in Chrome: signup, forgot password, reset link, sign in with the new password, audit log entries, reused reset link refused.

NOT DONE YET

- Live click-through of the Users, Companies and Audit pages as each of the three roles.
- Password reset email: the link is printed in the backend log until a mail server is set up.
- Refresh tokens, database migrations (tables are created at startup), CORS and production settings.
- Connecting the graph routes to the auth and company-scope helpers. The graph code is not in this repo.

CONFIDENTIAL

- Commit, push and PR. Directive checks run when you ask for them.

OPEN DECISION

Signup is open to anyone. Decide whether it stays open, becomes invite-only, or is limited.

CONFIDENTIAL